

CHAPITRE 2: ENDPOINT DETECTION AND RESPONSE (EDR)

I. Préambule

En mai 2017, le monde a découvert la puissance dévastatrice de l'attaque **WannaCry**. Ce ransomware, l'un des premiers à l'échelle mondiale qui s'est propagé à une vitesse fulgurante, infectant plus de **230 000 ordinateurs** dans **150 pays** en une **seule journée**. Les dommages, estimés à **plusieurs milliards de dollars**, ont prouvé qu'une simple faille pouvait paralyser des infrastructures critiques en un temps record.

En septembre 2023, **MGM Resorts**, a été paralysé en quelques heures par un ransomware, des hôtels dont les clés de chambre ne fonctionnent plus, des casinos où les machines à argent s'éteignent et des systèmes de réservation totalement hors-ligne. Cette attaque a coûté plus de **100 millions de dollars** à l'entreprise. Dans le cas de MGM, les attaquants n'ont pas utilisé de faille complexe, ils ont simplement utilisé la manipulation psychologique (Social Engineering) pour obtenir un accès.

De nos jours, le temps moyen de progression d'une cyberattaque (breakout time) n'est plus que de **48 minutes**. C'est le laps de temps infime dont dispose un attaquant entre son premier accès au réseau et le début de ses mouvements latéraux vers d'autres systèmes. Ces exemples montrent qu'une simple recherche des virus n'est plus suffisante, il faut sans aucun doute considérer également l'analyse de **comportements**. L'EDR devient ainsi un outil indispensable pour détecter les signaux faibles et permettre une réponse immédiate, avant que l'intrusion ne se transforme en catastrophe.

II. Notions générales

1. Qu'est-ce qu'un "Endpoint" (Terminal) ?

Dans le contexte de la cybersécurité, un endpoint est toute machine communicante et connectée au réseau de l'entreprise. Ces machines peuvent être des ordinateurs portables, postes de travail, serveurs, VDI, machine virtuelles et appareils mobiles utilisés au quotidien par les employés et leur emplacement peut être **sur site (on-premise)** et/ou **dans le cloud**. Ces machines représentent la cible numéro 1 des attaquants.



2. La visibilité

La visibilité d'un terminal (endpoint) est non seulement limitée à la capacité d'un analyste SOC à savoir exactement ce qui se passe sur un système à un instant "T", mais aussi ce qu'il s'est passé auparavant.

Chaque terminal peut être considéré comme un point d'entrée pour les attaquants. La visibilité transforme l'activité en compréhension, raison pour laquelle cette dernière est cruciale et incontournable pour une surveillance efficace.

La visibilité peut être vue sous trois angles :

- **Visibilité Temps Réel** : Voir les processus actifs, les connexions réseau sortantes et les fichiers modifiés à l'instant même.
- **Visibilité Historique** : grâce aux logs, l'analyste peut voir qu'un script a été exécuté il y a trois jours.
- **Visibilité Contextuelle** : Savoir que powershell.exe a été lancé par Word (considéré comme un comportement suspect) et non par un Administrateur (considéré comme un comportement normal).

Sans visibilité, une machine est une "**boîte noire**" : vous voyez qu'elle est allumée, mais vous ignorez si un processus malveillant est en train de chiffrer les fichiers en arrière-plan.

3. Types de menaces (Threats) : Connues vs Inconnues

- Les menaces connues (Known Threats)** : Cette catégorie de menaces représente l'ensemble des logiciels malveillants déjà répertoriés par la communauté de la cybersécurité. Ce sont les virus, rançongiciels ou chevaux de Troie dont l'empreinte numérique (le hash), ou "signature", est enregistrée dans des bases de données de référence. Pour ces menaces, l'Antivirus (EPP) classique assure une protection rapide et efficace, car elle repose sur une simple comparaison de hash.
- Les menaces inconnues (Unknown Threats / 0-Day)** : Cette catégorie de menaces exploite des vulnérabilités logicielles non encore découvertes par l'éditeur ou utilise du code polymorphe capable de changer sa propre structure à chaque infection. Dans ce cas, les signatures deviennent inutiles, car l'objet malveillant n'a jamais été vu auparavant, obligeant ainsi la défense à se concentrer non seulement sur ce que le fichier "est", mais aussi sur ce qu'il "fait". Pour ces menaces seule l'**analyse comportementale (EDR)** peut les détecter en observant des actions anormales (ex : une macro PowerPoint .pptm qui commence à crypter des fichiers).

4. Anatomie d'une attaque moderne :

Auparavant, une cyberattaque était essentiellement centrée sur le fichier malveillant lui-même. L'objectif était souvent de perturber le système ou de voler des informations de manière immédiate. Un utilisateur téléchargeait un exécutable (.exe), le lançait, et le virus tentait de se répliquer ou de corrompre des fichiers. La détection reposait quasi exclusivement sur le hash vu que le virus une fois activé, était "bruyant" et facile à repérer.

De nos jours, la cyberattaque est une opération structurée et persistante, elle ne repose plus sur un seul logiciel malveillant, mais sur une succession d'étapes minutieuses et en utilisant des outils considéré comme légitime au niveau de l'entreprise (ex : utilisation de PowerShell pour exécuter un script encodé)

Exemple d'étapes d'une attaque moderne :

- Reconnaissance : L'attaquant choisit son entreprise cible.
- Scan : L'attaquant choisit sa machine vulnérable ou employé(e) cible
- Armement (Weaponization) : Création du malware en fonction de la cible.
- Livraison (Delivery) : Envoi du mail de phishing ou exploitation d'une vulnérabilité.
- Commande & Contrôle (C2) : la machine établit un canal de **Commande et Contrôle (C2)**, permettant à l'attaquant de piloter le système à distance via Internet.
- Exploitation : Une fois à l'intérieur, l'attaquant ne déclenche pas immédiatement sa charge utile (payload). Il procède à une escalade de privilèges pour devenir administrateur, puis effectue un mouvement latéral pour naviguer d'un ordinateur à un autre dans l'entreprise.
- Installation : L'attaquant s'installe durablement et cherche les données les plus sensibles (serveurs de fichiers, base de données clients).
- Actions sur objectifs : vol massif de données confidentielles ou le déploiement d'un ransomware.

Dans ce cas de figure, l'attaque est fragmentée et chaque action prise isolément peut sembler légitime, c'est leur corrélation dans le temps qui révèle l'intrusion. Le concept de comprendre qu'une attaque n'est pas un événement isolé, mais une succession d'étapes est appelé "Cyber Kill Chain" permettant aux analystes de faire échouer une attaque en bloquant une seule étape

Les différences majeures entre les attaques anciennes et les attaques modernes :

- a. La durée et l'invisibilité** : Alors que les attaques anciennes étaient instantanées, les attaques modernes privilégient le "Dwell Time" ce qui signifie que l'attaquant reste caché des semaines ou des mois pour exfiltrer le maximum de données sans être détecté.
- b. Les attaques "fileless" (sans fichier)** : les attaques modernes privilégient le "sans fichier", elles injectent du code directement dans la mémoire vive (RAM) ou utilisent des scripts qui appellent des fonctions système autorisées comme PowerShell.
- c. Les attaques ciblées** : l'attaque ancienne visait n'importe quel ordinateur, l'attaque moderne est souvent **ciblée et adaptative**, si une barrière se présente, l'attaquant change de tactique en temps réel, contrairement au virus d'autrefois qui suivait un programme rigide.

5. Le Framework MITRE ATT&CK

Considéré comme le « livre sacré » de la cybersécurité et des analystes SOC, **MITRE ATT&CK** est un **modèle comportemental** de référence qui cartographie avec précision la manière dont les attaquants opèrent tout au long du cycle de vie d'une intrusion. Contrairement aux approches traditionnelles qui s'attardent sur les outils ou les logiciels malveillants utilisés, ce framework se concentre sur les objectifs des attaquants (**ce qu'ils tentent d'accomplir**) et sur leurs modes opératoires spécifiques (**comment ils s'y prennent**). Les analystes peuvent ainsi anticiper les

prochaines étapes d'une attaque et renforcer leurs capacités de détection en passant d'une simple constatation ("que s'est-il passé ?") à une compréhension stratégique ("que tente de faire l'attaquant ?")

Pour résumer, **MITRE ATT&CK** est une base de connaissance mondiale qui répertorie toutes les Tactiques et Techniques réelles des attaquants.

- **Tactique** : Le "Quoi" (ex : Comment l'attaquant obtient-il des accès ?).
- **Technique** : Le "Comment" (ex : Il utilise le Brute Force ou le Phishing).

Pour plus d'information sur les Tactiques et technique MITRE ATT&CK : <https://attack.mitre.org/>

6. Les piliers de la défense: Prévenir, Détecter, Répondre

Le modèle de sécurité moderne repose sur un principe simple : aucune barrière n'est infranchissable et aucun système n'est sans risque. C'est pourquoi nous divisons la stratégie de sécurité des terminaux en trois piliers : **Prévenir, Détecter, Répondre**.

- La Prévention** : c'est l'ensemble des solutions de sécurité mise en place afin d'empêcher une menace de s'exécuter ou une intrusion de se réaliser. L'objectif ici est de réduire la surface d'attaque en bloquant les fichiers malveillants connus, en filtrant les URLs dangereuses ou en interdisant l'exécution de macros non signées. La prévention est indispensable car elle élimine 90% des menaces. Cependant, si une menace est inconnue (Zero-Day) ou si elle n'utilise pas de fichier, la prévention échoue silencieusement.
- La Détection** : Puisque la prévention peut être contournée, il est essentiel de savoir quand un attaquant a franchi les murs c'est ici qu'intervient la détection. Contrairement à la prévention qui bloque l'action a priori, la détection identifie l'anomalie et déclenche une alerte. Elle repose sur la surveillance continue des comportements du système et des logs afin d'identifier des comportements suspects, ex : un processus qui injecte du code dans un autre, ou un compte utilisateur qui tente d'accéder à des fichiers sensibles de manière inhabituelle, un utilisateur qui se connecte depuis un pays à risque. Sans détection, le "Dwell Time" peut s'étendre sur plusieurs mois sans que le SOC ne s'en aperçoive.
- La Réponse** : Désigne les étapes à suivre pour une prise en charge efficace d'une alerte par le SOC. Elle débute par une phase d'**investigation** visant à qualifier l'alerte. Une fois la menace confirmée, un **incident** est ouvert dans un outil de **ticketing** pour assurer la traçabilité et la coordination entre les équipes. La réponse se conclut par des recommandations. Les recommandations du SOC peuvent aller d'une simple sensibilisation à un isolement de la machine pour une analyse Forensic. La réponse consiste à maîtriser l'incident de sécurité.

III. L'antivirus (EPP classique):

1. Définition

L'**EPP** (*Endpoint Protection Platform*) est une solution de sécurité préventive conçue pour bloquer les menaces connues avant qu'elles ne puissent s'exécuter. Son efficacité repose sur deux méthodes d'analyse principales :

- a. **L'analyse par signatures (Statique)** : C'est la méthode la plus ancienne. Chaque fichier malveillant possède une empreinte numérique (**Hash**). L'antivirus compare chaque fichier entrant à sa base de données de hash connus. Si le Hash correspond, le fichier est immédiatement bloqué ou mis en quarantaine. Cette méthode est totalement aveugle face aux menaces dont la signature n'est pas encore répertoriée.
- b. **L'analyse heuristique (Dynamique légère)** : Pour pallier les limites des hash, l'analyse heuristique recherche des caractéristiques suspectes dans le code sans avoir besoin d'une correspondance exacte. Elle examine la structure du fichier ou simule son exécution dans un environnement sécurisé et isolé (ex : Sandbox locale) pour voir s'il tente d'effectuer des actions typiques d'un malware, comme s'auto-répliquer ou modifier des fichiers système sensibles. Bien que plus efficace contre les variantes de virus connus, elle peut générer beaucoup de faux positifs.

2. Les limites de l'antivirus classique

L'objectif des attaquants aujourd'hui est simple : modifier l'apparence de la menace sans changer sa dangerosité. Ce qui signifie changer la signature et/ou rendre la menace indétectable (en n'utilisant aucun fichier) rendant les bases de données de signatures obsolètes. Parmi les limites des AV classique, nous citons :

- **Le Polymorphisme et le Métamorphisme** : Le polymorphisme est une technique où le malware utilise un moteur de chiffrement pour changer son apparence à chaque nouvelle infection. Bien que sa fonction malveillante reste identique, sa signature numérique (Hash) change systématiquement. Le métamorphisme va encore plus loin, le malware réécrit son propre code source. Il change ses instructions, réorganise ses fonctions et insère du code inutile pour que même l'analyse heuristique rencontre des difficultés à le détecter.
- **Les attaques "Fileless" (Sans fichier)** : Considérées comme la limite la plus critique de l'antivirus classique. Comme présenté précédemment cette attaque ne repose sur aucun fichier exécutable. Comme l'antivirus traditionnel scanne prioritairement les fichiers créés ou modifiés sur le disque, il est totalement aveugle face à une activité malveillante qui est présente que dans la mémoire. Sans analyse comportementale il est extrêmement complexe de détecter l'attaque.

Outre de ces limites, l'avènement du télétravail, la généralisation des services Cloud et l'utilisation de terminaux personnels (BYOD) ont permis la circulation des données bien au-delà des murs de l'entreprise. Les attaquants ont appris à contourner ces barrières en empruntant des voies légitimes et une fois les solutions de sécurité franchies, l'attaquant se retrouve souvent dans un environnement où il peut se déplacer librement.

Cette réalité a imposé le déplacement de la protection directement sur le terminal (l'endpoint), car il est désormais le seul endroit où la visibilité et le contrôle sont complets.

IV. Endpoint Detection and Response (EDR-doesn't wait for alerts - it watches behavior.)

1. Definition

L'**EDR** est une technologie de sécurité qui ne se concentre pas sur ce **qu'est un fichier**, mais sur ce **qu'il fait**.

Exemple : Une alerte s'est déclenchée au niveau du SIEM

Indiquant : «Suspicious PowerShell Activity on a Windows machine »

Mître tactic : TA0002

Mître technique : T1059

EventID : 4688 dans les logs sécurité de Windows sur la machine

Ce que l'**analyste voit** après investigation et corrélation **manuelle** :

- Etape 1 : outlook.exe (L'utilisateur a ouvert un mail)
- Etape 2 : winword.exe (Le mail contenait un document Word avec une macro)
- Etape 3 : cmd.exe (La macro a ouvert une invite de commande)
- Etape 4 : powershell.exe -enc JABzAD0ATgBIAHcAL... (La commande a lancé un script PowerShell chiffré)

L'analyse de l'EDR (Corrélation automatisée):

- Corrélation : L'EDR lie ces processus entre eux. Il comprend que c'est le document Word qui est à l'origine du PowerShell suspect.
- Enrichissement : Pour chaque étape, l'EDR ajoute des informations : "Ce script PowerShell communique avec l'adresse IP Russe 185.X.X.X réputée malveillante".
- Score de risque : L'EDR calcule que la probabilité qu'un document Word lance un script réseau chiffré est de 99% malveillante.

Outil	Ce qu'il voit	Action
Antivirus	Le fichier ne contient pas de virus connu, je l'autorise	"Le fichier ne contient pas de virus connu, l'AV l'autorise."
Analyste	Word -> CMD -> PowerShell Peut voir l'IP Russe s'il investigate les logs FW aussi	"Le comportement est anormal, l'analyste crée un incident de sécurité avec les recommandations SOC adéquates"
EDR	Enchainement Word -> CMD -> PowerShell -> IP Russe	"Le comportement est anormal, l'EDR alerte le SOC et bloque la connexion réseau si la politique de sécurité de l'entreprise le permet."

Sans EDR, l'antivirus voit peut-être le malware final, mais il ne sait jamais que tout a commencé par un simple mail Outlook trois heures plus tôt. Avec l'EDR, L'analyste ne perd pas de temps à chercher "qui a fait quoi". Il passe immédiatement à la phase de décision : "Est-ce que je coupe la connexion avec l'IP ? ", "est ce que je crée un incident de sécurité ? ", "est ce que je fais une analyse forensique ?", "est ce que je retire la machine en question du réseau pour éviter un mouvement latéral ?". L'investigation de l'analyste permet de corrélérer, mais l'EDR offre un Timeline visuel immédiat.

Même si chaque outil utilisé est "légitime" (PowerShell est un outil Windows sain), l'EDR détecte que l'**enchaînement des actions** est malveillant. Il lève une alerte critique et permet à l'analyste de bloquer l'attaque en direct.

2. Objectifs de l'EDR:

L'objectif de l'EDR n'est pas simplement de remplacer l'antivirus, mais d'ajouter des capacités que la prévention seule ne peut pas offrir :

- **Visibilité totale** : Enregistrer chaque action sur le terminal pour ne laisser aucune zone d'ombre à l'attaquant.
- **Détection des signaux faibles** : Identifier des comportements qui, pris isolément, semblent sains, mais qui deviennent suspects une fois corrélés (ex: un tableur Excel qui télécharge un fichier exécutable).
- **Réduction du "Dwell Time"** : Détecter l'intrusion en quelques minutes plutôt qu'en plusieurs mois.
- **Investigation accélérée** : Fournir à l'analyste SOC toutes les preuves nécessaires pour comprendre le "*comment*" et le "*pourquoi*" de l'attaque sans avoir à extraire manuellement les logs.

3. Comment la détection EDR Fonctionne

Avant d'aller plus loin, il faut comprendre deux notions très importantes dans le monde des EDR. On parle de l'**agent EDR** et de la collecte de la **téléométrie** :

a. L'agent EDR :

L'agent EDR est un logiciel léger déployé sur chaque terminal pour assurer une surveillance continue et une protection active. Son fonctionnement repose sur deux missions :

- **L'observation** : Au lieu de scanner l'intégralité du disque dur en permanence, l'agent "écoute" en temps réel les événements critiques du système d'exploitation. Il enregistre chaque création de processus, chaque accès aux fichiers sensibles, les modifications des clés de registre et les flux réseau. Cette collecte de données, appelée **téléométrie**, constitue la mémoire vive de tout ce qui se passe sur le terminal.
- **La capacité de réaction** : L'agent n'est pas qu'un simple témoin ; il est aussi le bras armé du SOC. Il applique les règles de prévention et exécute les ordres de réponse (comme l'isolement d'une machine ou l'arrêt d'un processus). Sa force réside dans son efficacité : il assure ces fonctions de détection et de blocage avec un **impact minimal sur les ressources** (CPU/RAM), garantissant que la sécurité ne ralentit pas le travail des utilisateurs.

b. La télémétrie :

- **Définition de la télémétrie :** La télémétrie désigne l'ensemble des informations collectées et transmises automatiquement par l'agent EDR pour se rendre compte de l'activité en cours sur une machine. Elle constitue le "journal de bord" ultra-détaillé de chaque événement survenant sur le terminal.
- **La Télémétrie "Endpoint" :** Elle englobe toutes les données de sécurité pertinentes remontées par l'agent depuis le terminal. Elle se décompose généralement en plusieurs flux :
 - **Processus :** Surveillance de l'ouverture et de l'exécution des programmes.
 - **Fichiers :** Traçabilité des créations, modifications ou suppressions de fichiers.
 - **Réseau :** Analyse des connexions entrantes et sortantes.
 - **Registre :** Détection des modifications suspectes dans les clés de configuration système.
 - **Logons :** Enregistrement des tentatives et succès de connexions utilisateurs.

c. La puissance de la visibilité EDR :

L'agent EDR offre une visibilité profonde permettant des **détections d'haute-fidélité**. En réduisant les faux positifs, il fournit le contexte nécessaire pour comprendre le **quoi**, le **comment** et l'**intention** de l'adversaire.

Capacités clés grâce à la télémétrie :

- **Détection d'abus :** Repérer le détournement d'outils légitimes (ex: PowerShell).
- **Traçabilité :** Comprendre chaque étape de la progression d'une attaque.
- **Contextualisation :** Analyser les comportements suspects avec tout leur historique.
- **Action directe :** Répondre aux menaces instantanément depuis le terminal.
- **Amélioration continue :** Durcir les défenses après chaque analyse d'incident.

d. Le processus de détection : De la donnée à l'incident

L'EDR prépare le travail de l'analyste en amont en transformant la télémétrie brute en contexte exploitable.

La capture et l'analyse :

Même si la plupart des leaders EDR du marché (95%) suivent l'architecture Cloud, il existe trois modèles d'architecture :

- **Les EDR "Cloud-Native" :** La télémétrie circule du **l'agent (i.e. capteur)** vers le **Cloud EDR**. C'est là que la puissance de calcul (IA et algorithmes) identifie des schémas malveillants (*patterns*) invisibles à l'échelle d'une seule machine et le transforme en incident de sécurité. Sans connexion, l'analyse "intelligente" est presque à l'arrêt.
- **Les EDR "On-Device AI" :** Le processus de détection (ML, Analyse comportementale) se passe **directement sur le PC**. L'incident est généré localement, puis envoyé au Cloud juste pour l'affichage sur la console.
- **Les EDR "On-Premise" :** fonctionne comme le "Cloud-Native" mais le "cloud" est remplacé par un **serveur local** dans l'entreprise.

Catégorie	Exemples de solutions	Pourquoi les choisir ?
Cloud-Native	CrowdStrike, cyberaison, Microsoft Defender	Simplicité de déploiement et puissance de l'IA mondiale.
On-Device	SentinelOne, Sophos	Protection maximale des postes même hors-ligne.
On-Premise	HarfangLab, Tehtris, KATA (Kaspersky Anti-Targeted Attack)	Souveraineté des données et secteurs sensibles (Secteur Défense).

Les leviers de détection

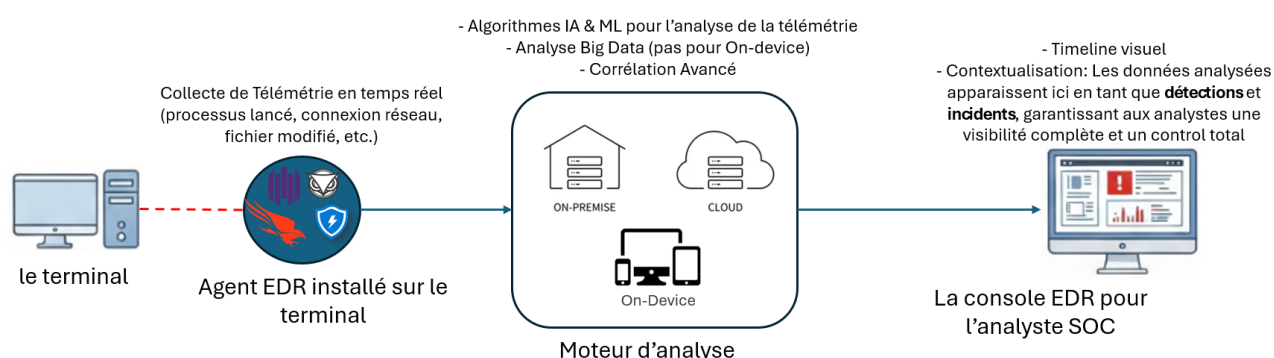
Les détections générées dans la console reposent sur quatre piliers :

- **Les 5 approches de détection que les EDRs utilisent :**
 - **L'approche IOA (Indicateurs d'Attaque) :** Portée par CrowdStrike, cette méthode se focalise sur l'intention. Au lieu de chercher des fichiers connus, l'EDR analyse des séquences d'actions suspectes (ex : un script qui tente d'extraire des mots de passe en mémoire).
 - **L'approche "Malop" (Opérations Malveillantes) :** Concept clé de Cybereason, elle privilégie la corrélation globale. Le système agrège des millions d'événements pour reconstruire visuellement toute l'histoire de l'attaque. Pour l'analyste, cela remplace des centaines d'alertes isolées par une seule vue d'ensemble cohérente.
 - **L'approche "Autonomie" (IA Locale) :** portée par SentinelOne, cette approche embarque l'intelligence de détection et de décision directement sur le terminal. L'agent prend des décisions de blocage instantanées sans solliciter le Cloud, garantissant une protection maximale même pour les machines hors-ligne (mode avion, sites isolés). Elle inclut souvent une fonction de "Rollback" pour annuler automatiquement les dégâts causés (ex: déchiffrement de fichiers).
 - **L'approche par l'Identité (ITDR - Identity Threat Detection and Response) :** Aujourd'hui, les attaquants ne cherchent plus seulement à "entrer" par un virus, ils cherchent à "se connecter" avec des identifiants volés. De ce fait, l'EDR ne se contente plus à surveiller le fichier ou le processus mais il analyse aussi le **comportement de l'utilisateur**.
 - **L'approche "Deception" (Leurre et Tromperie) :** C'est la stratégie du "pot de miel" (Honeytrap) intégrée directement dans l'EDR. L'EDR sème de faux fichiers, de faux mots de passe en mémoire ou de fausses connexions réseau sur le terminal. Si un attaquant y touche, l'alerte est immédiate et fiable à 100% (Zéro faux positif. C'est une détection "active").

Philosophie	Focus Principal	Acteurs Types
IOA	Intentions et Tactiques	CrowdStrike
Malop	Histoire complète de l'attaque	Cybereason
Autonomie	IA locale et détection offline	SentinelOne, Sophos
ITDR (Identité)	L'utilisateur / Privilèges	Microsoft Defender, CrowdStrike
Deception (leurre)	Le piège / Haute-fidélité	SentinelOne / Fortinet

- **Machine Learning** : Il sert à trier la masse de données. Il compare un fichier ou un comportement à des millions d'autres pour pouvoir prendre une décision sur la légitimité ou pas d'un fichier et/ou comportement. Ex : l'EDR peut dire qu'un fichier ressemble à 99% à un ransomware, même s'il ne l'a jamais vu avant.
- **Exploit Detection** : permet le repérage des tentatives de détournement de failles logicielles.
- **Analyse Comportementale** : permet la Surveillance des actions suspectes (ex: injection de code).

La figure suivante représente le cycle de détection de l'EDR et montre le chemin suivi par les logs en commençant du terminal (endpoint) jusqu'à la console EDR pour l'analyste.



4. La Réponse en temps réel (Real-Time Response)

Une fois la détection effectuée, l'agent lui-même devient l'outil d'action de l'analyste SOC tout en respectant la politique de sécurité de l'entreprise. Il permet aux analystes de se connecter à distance aux terminaux, d'exécuter des commandes, de collecter des données forensiques et de prendre des mesures immédiates. C'est un outil essentiel pour réduire le "*dwell time*" et accélérer la réponse aux incidents. Voici quelques actions qu'un agent peut effectuer :

- **Isolation Réseau** : Coupe toutes les connexions du terminal (sauf vers la console EDR) pour stopper la propagation.
- **Kill Process** : Arrête immédiatement l'exécution d'un processus malveillant en mémoire.
- **Quarantaine** : Neutralise ou supprime un fichier suspect du disque dur.
- **Remote Shell** : Ouvre un terminal à distance pour que l'analyste puisse nettoyer la machine ou collecter des preuves.

5. L'apport de la Threat Intelligence (CTI- Cyber Threat Intelligence) avec l'EDR

La Threat Intelligence se concentre sur la collecte et l'analyse de renseignements provenant du monde entier concernant les tactiques, techniques et procédures (TTP) des attaquants. L'objectif est d'anticiper les menaces avant qu'elles ne frappent l'organisation, offrant aux analystes ce qui suit :

- **Optimiser la Prévention** : en bloquant automatiquement les indicateurs de compromission (IoCs) connus, tels que les adresses IP malveillantes, les domaines de phishing ou les empreintes numériques (*hash*) de fichiers malveillants.
- **Accélérer la Détection et le Hunting** : en fournissant le contexte indispensable pour identifier des signaux faibles ou des activités suspectes complexes qui passeraient inaperçues sans référentiel externe.
- **Guider la Réponse** : en révélant l'identité, les intentions et les méthodes probables de l'attaquant, permettant ainsi de prendre des décisions de remédiation ciblées et efficaces.

6. Indicateurs de Compromission (IoC) vs Indicateurs d'Attaque (IoA)

a. IoC (Indicateur de Compromission) : Les preuves du passé

L'IoC est une preuve technique, souvent statique, confirmant qu'une intrusion a déjà eu lieu sur un système. Il fonctionne comme une signature ou une "empreinte digitale" laissée par un attaquant après son passage. L'IoC permet de détecter une menace connue en comparant les données actuelles à une base de connaissances de cyberattaques passées.

- Les indicateurs de compromission réseaux : il s'agit d'identifier les adresses IP, les URL, les noms de domaine, les connexions à des ports inhabituels ou même des ports ouverts inhabituels utilisés par l'attaquant et découverts au cours de la phase d'investigation. Ces informations, connues sous le nom d'IoCs, doivent être incluses dans votre rapport d'enquête final, afin de bloquer ces communications sur d'autres machines de votre réseau, et d'empêcher ainsi la propagation de la menace. Ces IoCs peuvent également être utilisés pour créer des règles de sécurité aux niveaux FW, Proxy, IPS/IDS, etc.
- Les indicateurs de compromission fichiers : dans ce cas, il s'agit de fichiers malveillants ou de signatures de logiciels malveillants :
 - **Hash de fichiers** : Comparer les hachages de fichiers (MD5, SHA1, SHA256) des fichiers malveillants connus ou des signatures de logiciels malveillants avec les fichiers sur le système. Chaque fichier ayant son propre hash, cette information est cruciale pour bloquer tout fichier ayant un hash malveillant dans les logiciels antivirus ou même dans les outils de gestion du courrier électronique, qui peuvent bloquer les courriels contenant un hash malveillant en pièce jointe.

- Noms de fichiers : Recherchez des noms de fichiers suspects ou connus pour être malveillants, ou des modèles de dénomination.
- Emplacement des fichiers : Vérifiez si les fichiers se trouvent dans des répertoires inhabituels ou inattendus, tels que des dossiers système ou des emplacements temporaires.
- Extensions de fichiers : Identifiez les fichiers dont l'extension est inhabituelle ou suspecte, comme .exe, .dll, .bat ou .vbs.
- Les indicateurs de compromission « adresses email » : si la compromission de la machine a été effectuée à travers la réception d'un email malveillant (exemple : phishing, URL malicieuse, etc.), l'adresse email émettrice de ce mail constitue aussi un IoC. Cette information permet de bloquer tout email en provenance de cette dernière.
- Les indicateurs de compromission système : si le logiciel malveillant effectue des actions sur le système, telles que
 - Création d'un service Windows spécifique.
 - L'exécution de processus ou de services suspects ou non autorisés sur le système.
 - Des comptes d'utilisateurs nouvellement créés ou modifiés qui peuvent indiquer un accès non autorisé.
 - Des changements dans les configurations du système : Identifier les modifications inattendues des paramètres du système, des entrées de registre ou des fichiers critiques.
 - Les actions administratives non autorisées, telles que les élévations de privilèges, les modifications de comptes ou les changements de politiques de sécurité.

Toutes ces actions constituent une liste d'IoC. Une analyse à distance peut être effectuée sur toutes les machines de l'entreprise afin d'identifier les machines compromises en utilisant le nom du service suspect découvert, le nom du compte utilisateur créé, etc.

L'avantage de l'EDR : Une fois qu'un IoC est découvert sur une seule machine (le "Patient Zéro"), l'analyste peut lancer une recherche instantanée sur l'ensemble du parc informatique pour identifier toutes les autres machines compromises.

b. IoA (Indicateur d'Attaque) : La détection du comportement

Contrairement à l'IoC qui cherche des "objets" (fichiers, IPs), l'**IoA** se concentre sur les **actions** et la **logique** de l'attaquant. Il permet de détecter une intrusion en cours en analysant les tactiques, techniques et procédures (TTPs).

- **L'analyse de l'intention** : L'IoA ne regarde pas "ce qu'est" le fichier, mais "ce qu'il fait". Grâce à la **télémétrie endpoint**, l'EDR surveille les flux de données en temps réel :
 - **Comportements suspects** : Un processus légitime (comme Word ou PowerShell) qui tente soudainement de se connecter à un serveur externe inconnu ou de modifier des fichiers système.
 - **Mouvements latéraux** : Un utilisateur qui tente d'accéder à plusieurs machines du réseau en un temps très court avec des privilèges élevés.
 - **Exfiltration** : Un volume anormal de données sortant vers une destination inhabituelle.
- **Détection des attaques "Sans Fichier" (Fileless)** : C'est la grande force des IoAs. Comme ils ne reposent pas sur un fichier physique (donc pas de Hash), ils peuvent identifier l'**injection de code**

(ex : injecte du code malveillant directement dans la mémoire vive d'un processus sain comme Edge.exe) ou L'**abus d'outils d'administration** (ex : 'utilisation détournée de commandes PowerShell pour exécuter des actions malveillantes sans jamais copier de malware sur le disque).

- **La robustesse face à l'évasion** : Un attaquant peut facilement changer le nom ou le hash d'un fichier (IoC), mais il lui est beaucoup plus difficile de changer sa **méthode de travail**.

Exemple : Pour voler des mots de passe, un attaquant doit presque toujours lire la mémoire du processus lsass.exe. L'EDR détectera cet **IoA** (la lecture de lsass) peu importe l'outil utilisé par le pirate.